

PRIVILEGED AND CONFIDENTIAL

ATTORNEY-CLIENT PRIVILEGED DOCUMENT // LEGAL WORK PRODUCT

TO: The Board of Directors, Raccine Conglomerate

FROM: Global Data, Privacy, and Cybersecurity Practice, DLA Piper

DATE: June 29, 2026

SUBJECT: Legal Advice Memorandum: Risk Assessment and Strategic Guidance on Kyberite Ransom Demand

Foreword

This memorandum addresses the critical security incident first detected on November 18, 2024, involving unusual network activity on Raccine's EU-based servers and the subsequent encryption of our internal Human Resources (HR) infrastructure.

Following the immediate deployment of cybersecurity forensic specialists A788, network scans identified a highly sophisticated toolset deployed by a threat actor operating under the moniker "Kyberite." Intelligence reports indicate that Kyberite utilizes the notorious LockBit ransomware architecture and has successfully targeted at least 10 retail conglomerates globally this year alone, accumulating more than \$50 million in illicit payouts.

The incident has escalated via direct extortion messaging delivered to our newly appointed Chief Executive Officer, Peter Gibbons. Kyberite has provided verified "proof of life" files confirming the successful exfiltration of 3 gigabytes of sensitive data over a 90-day window. Crucially, while initial internal assessments assumed employee files were safe, the exfiltrated cache has been verified to contain personal records belonging to both **500,000 customers** (including unencrypted names, addresses, payment information, order histories, and complaint files) and **internal Raccine employees**.

Operationally, Raccine's Information Security team has achieved a major win by safely rebuilding and restoring the HR system from secure offline backups, effectively mitigating the system encryption block. However, Kyberite has issued a final 7-day deadline demanding a ransom payment of **\$3 million USD in Bitcoin**, threatening the immediate publication of all customer, employee, and proprietary design files (including upcoming campaigns for the Marche and Apugliano brands, and the Gascony handbag designs) on the dark web if payment is withheld.

Executive Summary

While the Board of Directors faces intense commercial pressure to protect Raccine's brand reputation and safeguard the intellectual property of the upcoming 2025–2026 product lines, **authorizing the \$3 million ransom payment presents extraordinary, asymmetric legal risks.**

Our primary findings indicate that while an explicit, singular EU statute outlawing ransomware payments does not exist, executing a multi-million dollar cryptocurrency transfer to an organization deploying LockBit infrastructure directly intersects with strict liability international sanctions laws, anti-money laundering (AML) frameworks, and counter-terrorist financing (CTF) regulations.

Because our technical teams have successfully restored operational data availability via backups, the primary business risk has shifted from operational survival to intellectual property exposure. Paying the ransom does not legally or technically guarantee that Kyberite will delete the exfiltrated data. Conversely, authorizing the transaction without exhaustive compliance clearances could expose Raccine to catastrophic regulatory penalties and place individual Board members at risk of personal civil and criminal liability for breach of fiduciary duties.

We strongly recommend a complete suspension of payment logistics, immediate formal cooperation with European law enforcement, and the rapid execution of our mandatory customer and employee data breach notification campaigns.

Analysis of Ransom Payments

1. Statutes or Case Law Prohibiting Ransom Payments

Under current EU and Member State jurisprudence, there is no blanket statutory prohibition that explicitly criminalizes the act of paying a ransom to recover encrypted or stolen corporate data.

However, ransom payments do not exist in a legal vacuum. The act of transferring funds to an illicit international cybercrime syndicate is governed indirectly by national criminal codes and regional regulations. Under continental European legal frameworks, a corporate payment to an extortionist group sits in a dangerous grey area. If a company makes a payout with the knowledge that the funds will be used to optimize infrastructure for subsequent criminal offenses, the corporation can be investigated for facilitating criminal association or enabling extortion cycles.

2. Potential Implications of Sanctions Restrictions and Mitigation Strategies

The threat actor's explicit reliance on LockBit ransomware tools triggers immediate and severe economic sanctions considerations. The Council of the European Union has prolonged its restrictive measures framework against malicious cyberactors through 2026, creating an aggressive enforcement environment.

- **The Strict Liability Trap:** International sanctions frameworks (including the EU Sanctions Map and the US Department of the Treasury's OFAC regulations) maintain explicit asset freezes against LockBit's core developers, administrators, and affiliated digital wallets. Sanctions compliance is governed by a **strict liability standard**. This means that if Raccine transfers \$3 million in Bitcoin to a wallet tied to a sanctioned LockBit affiliate, Raccine is legally liable for a sanctions breach regardless of whether the Board had direct knowledge of the wallet's specific owner or lacked malicious intent.

- **Mitigation Strategy:** The Board cannot rely on a defense of "commercial necessity" or "duress" to excuse a sanctions violation. The only viable legal mitigation strategy is to enforce an absolute block on fund transfers until external cryptographic forensic experts execute an exhaustive, multi-layered "chain hopping" trace on the designated Bitcoin address to verify zero connection to known blocked entities or state-sponsored cyber-clusters.

3. Money Laundering or Terrorism Financing Concerns

By utilizing advanced cryptocurrency routing mechanisms, ransomware syndicates intentionally seek to wash criminal proceeds.

- **Anti-Money Laundering (AML) Directives:** The EU's recently activated Anti-Money Laundering Authority (AMLA) frameworks strictly regulate large-scale transactions involving virtual asset service providers. Knowingly or negligently injecting \$3 million into an unverified digital wallet controlled by an extortion network engages corporate liability for integrating illicit capital into the financial system, exposing Raccine to severe financial crime investigations.
- **Counter-Terrorist Financing (CTF):** Because LockBit infrastructure operates on a Ransomware-as-a-Service (RaaS) model, independent affiliates distribute portions of their earnings back to a centralized core. If intelligence networks link these centralized pools to state-aligned hybrid threat actors, designated terrorist organizations, or paramilitary entities, any corporate payout can be reclassified as an illegal financing mechanism under EU counter-terrorism statutes, carrying automatic criminal prosecution tracks.

4. Personal Liability Risks for the Board

Board members are bound by corporate governance principles to act with due diligence, prudence, and in the absolute best fiduciary interest of the enterprise.

- **The Corporate Waste Standard:** Paying a ransom offers zero legal recourse or binding contractual protection. Empirical data compiled by ENISA and the European Cybercrime Centre confirms that a high percentage of paying corporations are targeted a second time, receive corrupted decryption tools, or have their data leaked anyway by rogue affiliates. Authorizing a \$3 million expenditure to an anonymous criminal group with no guarantee of return represents a high-probability case of corporate waste.
- **Individual Director Liability:** If the Board votes to approve a cryptocurrency transaction that violates EU sanctions or AML regulations without pursuing exhaustive, documented diligence, individual directors can lose their corporate shield. This exposes board members to personal civil litigation from shareholders for breach of fiduciary duties, and potentially individual criminal liability for executing an illegal financial transaction.

5. Relevant Regulatory Guidance and Compliance Considerations

Supervisory bodies—including the European Data Protection Board (EDPB), the Irish Data Protection Commission (DPC), and the UK National Cyber Security Centre (NCSC)—universally command a non-payment approach.

From a data protection standpoint, paying a ransom does not satisfy or eliminate your compliance duties under the GDPR. Regulators do not consider a ransom payment an acceptable mitigation measure. Because the "proof of life" files have confirmed that the confidentiality of both customer and employee data has been permanently broken, Raccine's notification triggers under Articles 33 and 34 remain fully active. Furthermore, under Article 33(5), Raccine is under a strict accountability mandate to document the entire lifecycle of this breach within an internal register. If the company pays a ransom and attempts to obscure the scale of the leak, it faces the maximum administrative fine ceiling under Article 83(5): **up to €20 million or 4% of total worldwide annual turnover of the preceding financial year**, whichever is higher.

Recommendations

To insulate the Board from personal liability, preserve Raccine's enterprise standing, and navigate this crisis in total compliance with EU law, the Board must adopt the following resolution framework immediately:

1. **Formally Record Non-Payment Protocol:** Maintain a meticulous, legally privileged minutes log documenting that the Board has evaluated the ransom demand and has intentionally suspended payment options to strictly comply with EU economic sanctions, AML regulations, and to prevent corporate waste. This document serves as the directors' primary protective shield against subsequent governance claims.
2. **Report the Extortion to Law Enforcement:** Immediately report Kyberite's direct communication to the CEO, the specific Bitcoin deposit address, and the associated "proof of life" metadata to national cybersecurity units and Europol. This formal engagement demonstrates corporate good faith and keeps Raccine firmly inside the fine-mitigation pathways of GDPR Article 83(2)(f).
3. **Execute Dual-Track Notifications Without Undue Delay:** Because the "proof of life" files completely debunked our earlier assumption that employee records were safe, the Board must authorize two separate, plain-language notification tracks under GDPR Article 34:
 - *Track A (Customers):* Direct, transparent notification letters sent to the 500,000 affected customers containing actionable defense measures (e.g., credit freezes, rotating banking credentials).
 - *Track B (Employees):* Internal corporate notices delivered to our staff outlining exactly what HR files were exposed, pairing the disclosure with company-funded identity protection support.

4. **Enforce Intellectual Property Countermeasures:** Rather than trusting an extortionist's promise to delete the Gascony handbag blueprints, direct our specialized brand protection team to establish aggressive, automated online monitoring. Prepare pre-drafted intellectual property cease-and-desist and digital takedown notices to instantly combat any fast-fashion copycat operations the moment a replica surfaces on global marketplaces.